Linux Server Hardening Report: Ubuntu 26.04

Oct 15, 2026 · @loay

Executive summary

A default Ubuntu Server 26.04 install was hardened from a Lynis hardening index of **63 to 82** (+19 points, +30%), with no loss of service.

Key outcomes:

- **Password attacks on SSH are no longer possible.** Login now requires a cryptographic key; passwords and direct root login are refused.
- **The server blocks all inbound traffic except SSH**, and SSH itself is rate limited.
- **Attackers are banned automatically.** Fail2ban bans any IP after 3 failed logins in 10 minutes.
- **Security patches install themselves**, and 25 pending updates were applied.
- **Tampering and intrusions are now detectable** through rootkit scanning (rkhunter), file integrity monitoring (AIDE), and audit logging of account, sudo and SSH changes (auditd).
- Both Lynis software components that failed at baseline (intrusion prevention and malware scanner) now pass, and the firewall, installed but unconfigured at baseline, now enforces a default-deny policy.

The remaining Lynis suggestions were reviewed one by one; each is either low risk for this server or requires a rebuild, and is documented under Residual risks.

Scope and test environment

The target was a single, freshly installed Ubuntu server, treated as a client's new cloud VPS. All testing was done on a system I own, so no authorization issues apply.

Item	Value
Operating system	Ubuntu Server 26.04 LTS ("Resolute")
Platform	VirtualBox VM: 2 vCPU, 2 GB RAM, 20 GB disk

Item	Value
Network	VirtualBox NAT; host port 2222 forwarded to guest port 22 (SSH)
Admin access	SSH from a Windows laptop (PowerShell OpenSSH client)
Admin account	vboxuser (sudo)
Audit tool	Lynis 3.1.6, same version for every scan
Rollback	VirtualBox snapshots before each phase

In scope: operating system configuration, SSH, host firewall, intrusion prevention, patching, malware and integrity detection, logging, account policy, kernel parameters.

Out of scope: web applications, databases, network devices, penetration testing of running services.

Methodology and tools

The work followed a measure, fix, re-measure cycle, so every change is backed by before and after evidence.

1. **Baseline.** Run a full Lynis audit and record open ports, firewall state and SSH settings.
2. **Snapshot.** Take a VirtualBox snapshot before each phase, so any change can be rolled back in seconds.
3. **Harden in phases.** SSH, then firewall, then intrusion prevention, then patching, detection, logging and policy.
4. **Verify each phase.** Prove the control works, not just that it is configured (for example, a password login attempt must be refused).
5. **Re-audit.** Run the same Lynis version again after round 1 and round 2, and compare scores.
6. **Triage leftovers.** Review every remaining suggestion and either fix it or document why it is accepted.

Tool	Used for
Lynis	Security audit and hardening score

Tool	Used for
ss	Listing listening ports (attack surface)
OpenSSH (ssh-keygen, sshd -T)	Key generation and verifying the live SSH config
UFW	Host firewall
Fail2ban	Automatic banning of brute-force sources
unattended-upgrades	Automatic security patching
rkhunter	Rootkit and malware scanning
AIDE	File integrity monitoring
auditd	Kernel-level audit logging

All configuration was placed in separate drop-in files (for example `sshd_config.d/01-hardening.conf`, `jail.local`, `sysctl.d/99-hardening.conf`) rather than editing vendor files. This keeps changes easy to review, survives package updates, and can be undone by deleting one file.

Baseline findings (before)

The default install scored **63/100** across 252 Lynis tests, with no intrusion prevention and no malware detection.

Area	Finding at baseline	Risk
Intrusion prevention	None installed (Lynis: [X])	Unlimited password guessing against any login service
Malware detection	None installed (Lynis: [X])	A rootkit or backdoor would go unnoticed
Firewall	Installed but not configured with rules	Any service that opens a port is exposed
Patching	25 updates pending, no automatic updates	Known vulnerabilities stay open

Area	Finding at baseline	Risk
Remote access	No SSH server installed	Needed for administration; when installed, Ubuntu defaults allow password login
Audit logging	No auditd	Changes to accounts or sudo rights leave no trail
Password policy	No expiry, default hashing rounds	Weak or old passwords persist
Kernel network settings	Default values (ICMP redirects accepted, no martian logging)	Traffic redirection and spoofing are easier
File permissions	Default umask 022	New files readable by every local user
Legal banner	Not present	Weaker legal position against intruders

Listening services at baseline were limited to local-only resolvers and time sync (systemd-resolved on 127.0.0.53/54, chrony on 127.0.0.1:323) plus the DHCP client. This is a small attack surface, so the main gaps were missing controls rather than exposed services.

Hardening actions performed

Ten controls were applied in two rounds; round 1 raised the score to 72 and round 2 to 82.

Phase 1: SSH key-only access

Why: SSH is the main way into a Linux server, and bots try passwords against it around the clock. Keys cannot be guessed.

1. Generated an Ed25519 key pair on the admin laptop, protected by a passphrase. The private key never leaves the laptop.
2. Installed the public key in `~/.ssh/authorized_keys` on the server (folder 700, file 600 permissions).
3. Confirmed key login worked before disabling passwords, to avoid a lockout.
4. Applied the drop-in file `/etc/ssh/sshd_config.d/01-hardening.conf`:

```
PermitRootLogin no
PasswordAuthentication no
KbdInteractiveAuthentication no
PubkeyAuthentication yes
MaxAuthTries 3
LoginGraceTime 30
X11Forwarding no
AllowTcpForwarding no
AllowAgentForwarding no
ClientAliveInterval 300
ClientAliveCountMax 2
MaxSessions 2
TCPKeepAlive no
LogLevel VERBOSE
AllowUsers vboxuser
```

Setting	Effect
PermitRootLogin no	The root account, the first target of every attack, cannot log in over SSH
PasswordAuthentication / KbdInteractiveAuthentication no	Password guessing becomes impossible
MaxAuthTries 3, LoginGraceTime 30	Limits attempts per connection and how long a connection may sit unauthenticated
X11 / TCP / Agent forwarding no	Closes tunnelling features attackers use to pivot deeper into a network
ClientAlive, MaxSessions, TCPKeepAlive	Drops idle sessions after about 10 minutes and limits sessions per connection
LogLevel VERBOSE	Logs the fingerprint of the key used for every login
AllowUsers	Only the named admin account may use SSH

The file is named `01-` because SSH uses the first value it reads, so it overrides vendor files such as `50-cloud-init.conf` that may re-enable passwords. The config was syntax-checked with `sshd -t` before restarting.

Verified: a login attempt with keys disabled returned `Permission denied (publickey)`, and `sshd -T` confirmed the live values.

Phase 2: Host firewall (UFW)

Why: a default-deny firewall means a service started by mistake is still not reachable from outside.

```
ufw limit 22/tcp
ufw default deny incoming
ufw default allow outgoing
ufw logging on
ufw enable
```

`limit` allows SSH but blocks an IP that opens more than 6 connections in 30 seconds. Blocked traffic is logged to `/var/log/ufw.log`.

Verified: `ufw status verbose` shows active, deny incoming, and 22/tcp LIMIT.

Phase 3: Intrusion prevention (Fail2ban)

Why: fail2ban reads the login logs and bans repeat offenders in the firewall automatically.

`/etc/fail2ban/jail.local`:

```
[DEFAULT]
bantime = 1h
findtime = 10m
maxretry = 3
banaction = ufw

[sshd]
enabled = true
port = 22
backend = systemd
```

Three failures within 10 minutes means a one-hour ban, enforced through UFW. `jail.local` is used because package updates overwrite `jail.conf` but never `.local` files.

Verified: banned the documentation-range test address 203.0.113.50 manually and confirmed it appeared in both `fail2ban-client status sshd` and the UFW rules, then unbanned it.

Phase 4: Patching

Why: unpatched software is the most common way servers are compromised.

- Applied all 25 pending updates with `apt upgrade`.
- Enabled `unattended-upgrades` so security updates install daily without manual action (`/etc/apt/apt.conf.d/20auto-upgrades`).
- Added `apt-listchanges` (shows changes before upgrades) and `apt-show-versions` (lists packages needing patches).

Phase 5: Malware and integrity detection

Why: prevention can fail; detection tells you when it has.

- **rkhunter:** baseline of system file properties recorded with `rkhunter --propupd`, then a full rootkit scan.
- **AIDE:** a database of cryptographic hashes of important files, initialised with `aideinit`. Running `aide --check` later lists every file that changed.
- **debsums:** verifies installed package files against the official checksums.

Phase 6: Kernel network hardening

`/etc/sysctl.d/99-hardening.conf` changes kernel behaviour at runtime:

Setting	Protects against
accept_redirects = 0, send_redirects = 0	Attackers rerouting traffic with forged ICMP redirects
rp_filter = 1	Packets with spoofed source addresses
log_martians = 1	Logs packets with impossible source addresses
tcp_syncookies = 1	SYN flood denial of service
icmp_echo_ignore_broadcasts = 1	Smurf (broadcast ping) floods
kptr_restrict = 2, dmesg_restrict = 1	Leaking kernel memory addresses that help exploit writers
fs.suid_dumpable = 0	Privileged programs leaking secrets into crash dumps

Phase 7: Audit logging and accounting

Why: after an incident, logs are the only way to know what happened.

- **auditd** with rules in `/etc/audit/rules.d/hardening.rules` watching `/etc/passwd`, `/etc/shadow`, `/etc/group`, `/etc/sudoers`, `/etc/sudoers.d/` and the SSH config. Every change is logged with who made it and is searchable, for example `ausearch -k identity`.
- **acct** (process accounting) logs every command executed.
- **sysstat** keeps performance history, useful for spotting crypto-miners or denial of service.

Phase 8: Account and password policy

- `/etc/login.defs`: passwords expire after 90 days (`PASS_MAX_DAYS 90`), minimum 1 day between changes, stronger hashing rounds.
- `chage` applied the same expiry to the existing admin account.
- `libpam-pwquality` enforces strong local passwords; `libpam-tmpdir` gives each user a private temp folder.
- `UMASK 027`: new files are no longer readable by other users.

Phase 9: Attack surface reduction

- USB storage and four rarely used network protocols (DCCP, SCTP, RDS, TIPC) blocked in `/etc/modprobe.d/hardening.conf`. Servers do not need them, and these protocols have a history of kernel vulnerabilities.
- Compilers restricted to root, so an attacker with a normal account cannot build exploit code on the server.

Phase 10: Legal banner

`/etc/issue` and `/etc/issue.net` now state that access is restricted to authorised users, that activity is monitored, and that unauthorised use may be prosecuted. This supports legal action against intruders in many jurisdictions.

Results: before vs after

The hardening index rose from 63 to 82, and every failed Lynis software component now passes.

Measure	Baseline	After round 1	After round 2
Lynis hardening index	63	72	**82**
Tests performed	252	262	263
Firewall	Installed, unconfigured	Active, default deny	Active, default deny
Intrusion software	Missing [X]	Fail2ban [V]	Fail2ban [V]
Malware scanner	Missing [X]	rkhunter [V]	rkhunter + AIDE [V]
SSH password login	Not applicable (no SSH)	Refused	Refused
Pending updates	25	0, automatic	0, automatic

The test count grew because Lynis runs extra checks once software such as fail2ban and auditd is present. Lynis also printed two harmless notices on every run: its packaged version is over six months old, and Ubuntu 26.04 is newer than its end-of-life database.

Residual risks and accepted items

The suggestions left open after round 2 are not a direct path into the server; each is accepted, deferred or not applicable for a stated reason.

Suggestion	Decision	Reason
Set a GRUB boot loader password	Accepted	Exploiting it needs console or physical access; on a cloud VPS the provider controls the console
Separate /home and /var partitions	Accepted	Must be planned at install time; recommend for new production builds
Move SSH off port 22	Accepted	Only hides from bots; key-only login plus fail2ban already stop them
Send logs to an external log host	Deferred	Needs a second server; key recommendation for production

Suggestion	Decision	Reason
Install apt-listbugs	Not applicable	Debian bug-tracker tool, not meaningful on Ubuntu
Harden individual systemd services	Deferred	Per-service sandboxing, advanced future work
Remaining sysctl profile differences	Deferred	Need testing per workload to avoid breaking networking
Restrict further file permissions	Deferred	Needs case-by-case review of the flagged files
DNS domain name and FQDN in /etc/hosts	Accepted	Cosmetic for a standalone lab server
Configuration management tooling	Accepted	Relevant for fleets, not one server
Check deleted files still in use	Accepted	Informational; usually cleared by a reboot after updates

On a real client server I would confirm each accepted item with the owner, since business needs (for example, a required open port) can change the decision.

Recommendations for production

For a client's live server, five further steps would raise both security and recoverability.

1. **Central logging.** Forward logs (rsyslog or a SIEM agent) to a separate host, so an attacker who gets in cannot erase their tracks.
2. **Alerting.** Email or chat alerts on fail2ban bans, AIDE changes and rkhunter warnings, with `aide --check` and `rkhunter --check` scheduled daily.
3. **Backups.** Automated, off-server, tested restores. Hardening reduces the chance of an incident; backups limit its damage.
4. **Cloud firewall.** Add the provider's network firewall in front of UFW, and restrict SSH to known admin IP addresses or a VPN.
5. **Re-audit regularly.** Re-run Lynis monthly and after major changes, and keep the score trend in the client's records.

Evidence index

Every claim in this report is backed by a screenshot or raw output file in the project folder.

File	Proves
01-before-lynis-score.png	Baseline hardening index 63
02-before-ports.png	Listening ports at baseline
before-lynis.txt, before-ports.txt	Full baseline audit and port list
03-ssh-config-file.png	SSH hardening drop-in file
04-ssh-password-denied.png	Password login refused
05-ssh-config-active.png	Live SSH settings from sshd -T
06-firewall-status.png	UFW active with default deny and SSH limit
07-fail2ban-status.png	Fail2ban sshd jail running
08-fail2ban-ban-test.png	Test IP banned in fail2ban and UFW
09-auto-updates.png	Automatic security updates enabled
10-rkhunter-scan.png	Rootkit scan result
11-kernel-hardening.png	Kernel settings applied
12-after-lynis-score.png	Round 1 score 72
after-lynis.txt, after-ports.txt	Round 1 audit and port list
13-auditd-rules.png	Active audit rules
14-final-lynis-score.png	Final score 82
final-lynis.txt	Full final audit
round2.sh	Script used to apply round 2

Glossary

Plain-language definitions of every tool and term used in this report.

Term	What it is
Hardening	Reducing a system's attack surface by removing, disabling or tightening anything not needed
Attack surface	Everything an attacker can reach: open ports, services, accounts, installed software
Lynis	Free open-source auditing tool that runs hundreds of checks and gives a hardening index out of 100
Hardening index	Lynis's score for how many of its recommended controls are in place; useful for before and after comparison, not an absolute measure of safety
SSH	Secure Shell, the encrypted protocol used to log in to and manage Linux servers remotely
sshd	The SSH server program that accepts incoming connections
Key pair (Ed25519)	A private key kept secret on the admin's machine and a public key placed on the server; only the matching private key can log in
Passphrase	A password that protects the private key file, so a stolen key cannot be used on its own
known_hosts	File on the client that remembers each server's identity, to detect impersonation (man-in-the-middle)
Brute force	Guessing passwords automatically at high speed
Firewall (UFW)	Uncomplicated Firewall, Ubuntu's front end for the kernel firewall; decides which traffic may enter or leave
Default deny	Firewall policy that blocks everything unless a rule explicitly allows it
Fail2ban	Watches logs for repeated failures and bans the source IP in the firewall
unattended-upgrades	Ubuntu service that installs security updates automatically

Term	What it is
Rootkit	Malware that hides itself and gives an attacker hidden, persistent control
rkhunter	Rootkit Hunter, scans for known rootkits, backdoors and suspicious file changes
AIDE	Advanced Intrusion Detection Environment; stores file hashes and reports any file that changes
auditd	Linux audit daemon; logs security-relevant events such as changes to accounts or sudo rights
Process accounting (acct)	Records every command run on the system
sysctl	Interface for changing kernel parameters at runtime
ICMP redirect	Network message telling a host to send traffic another way; can be forged to intercept traffic
SYN flood	Denial-of-service attack that exhausts a server with half-open TCP connections
Kernel module	Driver or feature loaded into the kernel on demand, such as USB storage or a network protocol
umask	Default permissions applied to newly created files
PAM	Pluggable Authentication Modules, the Linux framework that controls logins and password rules
Drop-in config file	A small file in a `.d/` folder that overrides defaults without editing the vendor's main file
Snapshot	A saved state of a virtual machine that can be restored instantly
203.0.113.0/24	IP range reserved for documentation and testing; safe to use in examples